

Objectives

Part 1: Creating a Data Flow Diagram of the Home IoT System

Part 2: Creating a Risk Assessment using DREAD

Part 3: Selecting a Risk Response for the Rated Risks

Part 4: Considering Risk Mitigation Strategies

Required Resources

- Packet Tracer 7.1 or later

Background/Scenario

In this Packet Tracer, you will complete your threat model of the IoT home automation. Now that you have worked with all three layers of the IoT attack surface, you can create a basic data flow diagram of the system. This will help you to understand the system at a functional level and create trust boundaries that will help with understanding security risks.

You will use your STRIDE tables from the physical, communication, and application layers of the IoT attack surface and apply the DREAD model to create risk metrics for some of the threats. Normally, a threat model would include risk metrics for all of the relevant threats that have been identified, however, for the sake of time, you will work with only some of them.

After creating the risk metrics, you will decide how to respond to the risks using the four Ts risk response model.

Part 1: Creating a Data Flow Diagram of the Home IoT System

You have completed your asset inventories in previous Packet Tracers. You have also completed diagrams of the physical network, including the connections between devices and the types of protocols in use. Now you need to create a high level data flow diagram. This process is adapted from the [Microsoft IoT Security Architecture](#).

Follow the model data flow diagram and process provided in the course content and do the following:

- Think about the possible zones in the system. Create a zone for the sensors and actuators, the communication infrastructure device, and the cloud application. Think about the data stores and processes that could exist as cloud services. Connect these zones with arrows to indicate the type of communication between them.
- What external entities access the system? Add the entities and lines to connect them to the zones that they have access to and the system they access. Think of the types of applications and protocols that each use, as well as the functions described in previous Packet Tracers.
- Draw trust boundaries.

GitHub note: The diagram image is available in full quality for comfortable viewing at

<https://www.github.com/x-alted/cybersecurity-portfolio/Threat-Modelling-Diagram.png>

and at the bottom of this document.

Part 2: Creating a Risk Assessment using DREAD

Previously you created device inventories and identified vulnerabilities in them using the STRIDE model. The next step is to use a scoring mechanism that allows you to determine and prioritize risk. The DREAD system lets you do this by creating a composite risk metric that consists of scores for the five DREAD risk categories:

- **Damage potential** - What is the degree of impact on the organization's assets? (1 = low impact, 3 = high impact)
- **Reproducibility** - How easily can a variety of threat actors reproduce the attack? (always 3 - easy)
- **Exploitability** - How easy is the attack to execute? (1 = difficult, 3 = easy)
- **Affected Users** - Who and how many users will be affected? (1 = few, 3 = many)
- **Discoverability** - How easily can the vulnerability be found? (always 3 - easy)

For the purposes of this Packet Tracer, make the following assumptions. First, because this is a home automation system, assume that all members of the family that live in the home will be affected by any exploit. In addition, it is recommended that the reproducibility and discoverability metrics always be rated as high. Therefore, the metrics Reproducibility, Affected Users, and Discoverability metrics have already been scored as 3 for all vulnerabilities.

In an actual risk assessment, the A metric would not be assumed to be 3. However, it is recommended that R and second D always be rated 3.

- Use the following table to grade your previously discovered threats according to the scoring explanation shown above. Normally, every relevant identified threat would be rated. However, for the purposes of this task, you can choose several threats from each of the three elements of the IoT attack surface that we have discussed.

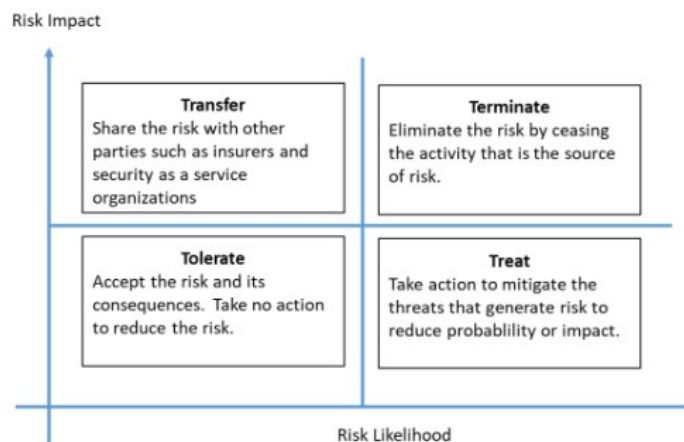
Attack Surface and Threat	D	R	E	A	D	Total
Solar panel	2	3	1	3	3	12
Smart window	3	3	2	3	3	14
Smart water meter	2	3	2	3	3	13
Smart alarm	3	3	3	3	3	15
Smart phone	3	3	2	3	3	14
Smart fan	1	3	1	3	3	11
Smart door	3	3	2	3	3	14
Smart coffee maker	1	3	1	3	3	11
Garage door	3	3	2	3	3	14
Smart battery	2	3	1	3	3	12
Smart sprinkler	1	3	1	3	3	11

- b. Put the risks in order by the highest to lowest DREAD metric and estimate the likelihood that the risk will occur. Do this by copying the risks over, or by marking up the table that you completed above. Score the likelihood as 1 for unlikely and 3 for very likely.

Attack Surface and Threat	Total	Likelihood
Smart alarm	15	3
Smart phone	14	3
Garage door	14	2
Smart window	14	2
Smart door	14	3
Smart water meter	13	2
Smart battery	12	3

Part 3: Selecting a Response for the Rated Risks

Refer to the four risk treatments in the graphic below. According to your risk ratings and likelihoods, decide how the risks should be handled.



Threat	Risk Response
Smart Alarm Denial of service via jamming	Terminate – Implement a physical secure pin code. Remove the ability to disarm remotely. Treat – Actively log all sensor / alarm communications.
Smart Door Direct risk of physical breach	Treat – Implement additional layers of security controls including audit logs. And MFA. Secure door using rolling code encryption and mechanical backups. A physical key.
Smart Window Direct risk of breach via sensor bypass	Treat – Implement sensor redundancies and mechanical overrides. Ensure function of physical locking mechanisms.
Smartphone Risk of credential theft.	Treat – Implement MFA and network restrictions. Implement VPN usage, biometric authentication, verify user group permissions.
Garage Door Risk of breach via stolen credentials or exploit	Treat – Secure door with rolling code encryption. Secure door using rolling code encryption and mechanical backups. Actively log all sensor communications.
Smart Water Meter Risk of data manipulation leading to dirty water	Tolerate – Manually verify an acceptable risk level and adjust.
Smart Battery Risk of UPS firmware tampering	Treat – Maintain consistent firmware updates. Keep logs of activity. Utilize VLAN segmentation.

What other factors should be considered when make a risk response determination besides the risk rating and likelihood?

Other factors that should be considered when making a risk response determination include the cost and resources needed to mitigate the risk, how complex the risk is; a complicated risk may require a more Indepth response, the response could create another risk, etc.

Part 4: Considering Risk Mitigation Strategies

Finally, any risks that have been identified with a "treat" response need to be mitigated.

Threat	Risk Response	Mitigation Strategy
Smartphone	Treat	Having the phone use a vpn and on a secure network, even as much as limited IPs of known unsecure websites and apps
Smart battery	Treat	Have the smart battery on a monitored system checking for power flow, aswell as having it on a secured and separate VLAN
Smart door	Treat Terminate	If the smart door is hooked up to a voice system have a internal radius of voice commands, also having it on its on VLAN disconnected from other devices.